

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC102 – Information Security Governance

WEEK 3 PRACTICAL LABORATORY

Roles, Responsibilities and Accountability in Security Governance

TechGlobal Governance Transformation Simulation

Lead Security Governance Consultant Report

Submitted by: Abigail Ugoeze Silas

Student ID: C11_26_CGRCE_17260

GRC Engineering Programme — Cohort 11

Executive Summary

TechGlobal is a 2,500-person technology firm with operations spanning five global offices, but the security governance framework employed by the firm has not been able to scale as the firm grows. The decision making process is centered around the IT Director, the governance responsibility is undefined and unrecorded, and there is no formalized cyber-risk reporting to the Board. In this report, written from the position of Lead Security Governance Consultant, a comprehensive governance framework change initiative will be outlined covering the following five tasks:

- Task 1: Governance Architecture and Stakeholders Map — highlights five weaknesses in the current structure and outlines a scalable governance framework with reporting lines and oversight relationships.
- Task 2: Governance Responsibility and Authorities Matrix — outlines purpose, decision authority, reporting, and KPIs of each of the eight governance positions with three conflict resolution mechanisms.
- Task 3: Security Governance Committee Ecosystem — outlines the Executive Security Council, Security Governance Committee, Cloud Security Working Group and a Business Unit participation model, terms of reference, sample agenda, decision log, and a one-year schedule.
- Task 4: RACI Accountability Matrix — outlines 15 governance processes and identifies a single accountable owner for each process.
- Task 5: Cyber Risk Escalation and Segregation of Duties — outlines three-tier escalation mechanism, escalation thresholds, and highlights five segregation of duties weaknesses with control measures.

All recommendations are based on ISO/IEC 27001:2022, NIST Cybersecurity Framework, NCSC Board Toolkit, and CISA CISO Handbook. The proposed framework should be practical, proportionate for a 2,500-person technology company, and auditable.

TASK 1 — Governance Architecture and Stakeholder Map (20 Marks)

EVIDENCE: Evidence Bundle 1: Gap Assessment · Stakeholder Map · Org Chart · Justification

1.1 Governance Gap Assessment

TechGlobal's current 'security by informal decision' model contains five material structural weaknesses, each of which creates identifiable business and risk consequences.

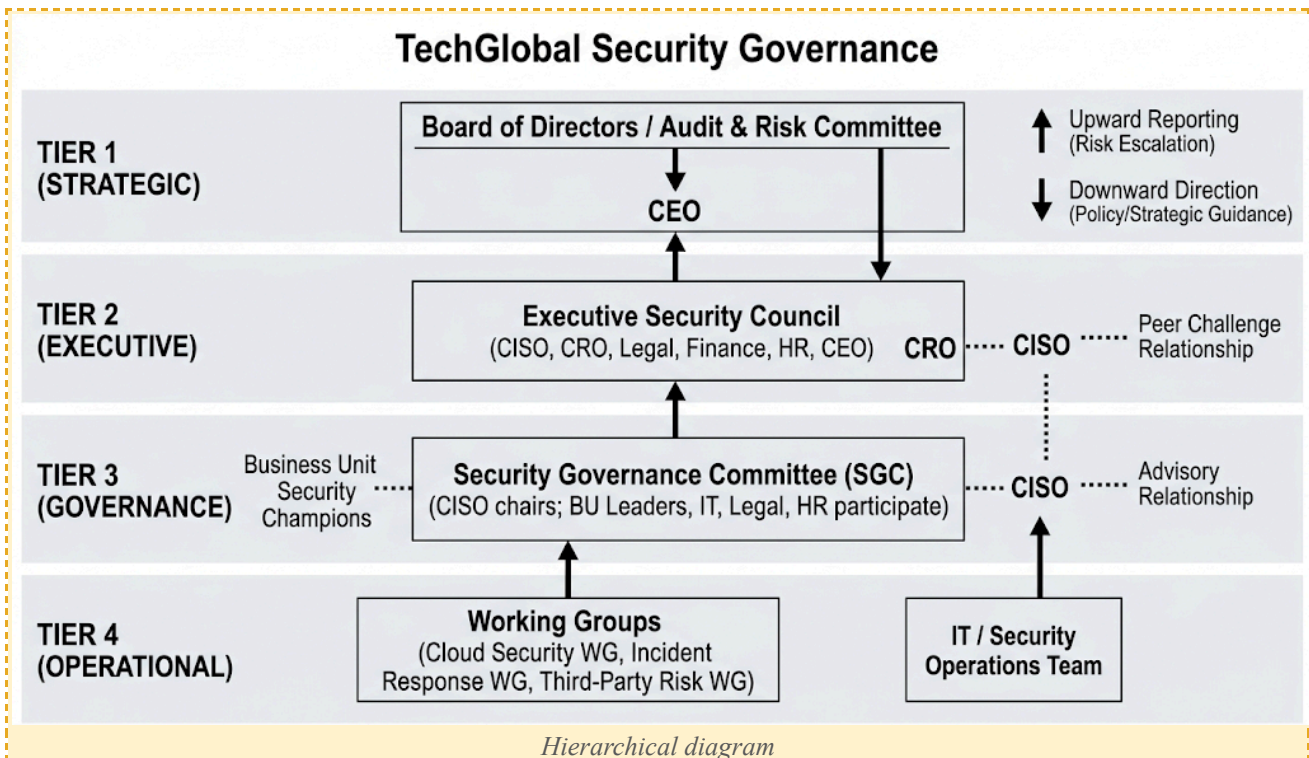
#	Weakness	Description	Business / Risk Consequence
1	Concentration of Authority in the IT Director	The IT Director acts simultaneously as security owner, risk approver, change authoriser, and operational decision-maker. There is no separation between those who implement controls and those who approve risk.	Creates a single point of failure. If the IT Director is unavailable, decisions stall. Removes independent challenges from risk decisions. Increases fraud and error risk through the absence of a four-eyes principle. Regulators and auditors view concentrated authority as a material governance deficiency.
2	No Formal Board or Executive Cyber-Risk Visibility	The CEO and Board receive no structured cyber risk reporting. Cyber-risk decisions are made at a mid-management level with no executive oversight.	The Board cannot fulfil its fiduciary duty of care on material cyber risk. Directors may have personal liability exposure under legislation requiring board-level accountability (e.g., NIS2, SEC rules). Investors and insurers view the absence of Board oversight as a governance red flag.
3	Inconsistent Business-Unit Control Ownership	Business units make local security decisions without coordination, defined standards, or oversight. No single function is accountable for enterprise-wide control consistency.	Inconsistent controls create exploitable gaps between business units. A breach in one unit can propagate across the organisation. Regulatory assessments will find non-uniform compliance, increasing penalty risk. Audit findings cannot be tracked to a responsible owner.
4	Absence of Formal Governance Committees	There are no structured forums — no security steering committee, no risk committee, no executive security council — for cross-functional decision-making on security matters.	Decisions are made unilaterally, without challenge or consensus. Security investments cannot be properly prioritised. Conflicts between IT, Legal, Finance, and Business Units are resolved informally or not at all. No auditable record of governance decisions exists.
5	No Defined Escalation or Risk Acceptance Process	There are no documented criteria for when a security risk must be escalated beyond the IT Director, nor any documented risk-acceptance authority or process.	An individual accepts or defers material risks without authority to do so. Board-level risks are never escalated to where they belong. Incident response is inconsistent and reactive. Regulatory breach notification timelines are at risk of being missed.

1.2 Stakeholder Map

The stakeholder map below defines the authority, interests, information requirements, and governance contributions of all nine key stakeholder groups in TechGlobal's proposed governance model.

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
Board of Directors	Highest — ultimate fiduciary authority; approves risk appetite and strategy	Regulatory compliance, brand protection, material risk assurance, shareholder value	Quarterly CISO cyber-risk dashboard; material incident notifications; annual security posture report; Board risk register updates	Approves cyber-risk appetite; ratifies security strategy; holds CEO accountable; provides independent oversight
CEO	Executive authority — sets strategic direction and holds executive team accountable	Business growth, strategic alignment, acceptable cyber-risk, reputation	Monthly executive security summary; immediate notification of Critical incidents; Budget requests from CISO	Bridges Board risk appetite and operational delivery; resolves executive-level conflicts; approves major risk decisions
CISO	Functional authority over security programme; direct mandate across all departments	Security programme effectiveness, policy compliance, incident governance, regulatory alignment	All incident data; control effectiveness metrics; risk register; regulatory developments; budget status	Defines security strategy; owns RACI; chairs Security Governance Committee; reports to Board; drives programme delivery
CRO / Risk	Enterprise risk integration authority; aggregates and challenges risk assessments	Integrated risk view, risk methodology integrity, risk appetite alignment	CISO risk register; incident data; third-party risk assessments; financial exposure estimates	Maintains enterprise risk register; validates CISO risk quantification; provides independent risk challenge; reports to Board Risk Committee
Legal / Compliance	Advisory authority on regulatory and contractual matters; decision authority on breach notification	Regulatory compliance, contractual integrity, privacy, litigation avoidance	Incident timelines; data categories involved; regulatory notification deadlines; contract terms with vendors	Advises on breach notification obligations; approves external security communications; provides legal privilege for investigations
Finance	Budgetary authority; financial governance and control	Security ROI, cost exposure, insurance adequacy, financial controls	Security budget requests; cost of incidents; cyber insurance renewal data; breach financial impact estimates	Approves and controls security budget; quantifies financial risk exposure; manages insurance; validates cost-benefit of security investments
Human Resources	People management authority; joiner/mover/leaver process ownership	Insider risk management, policy compliance, employee conduct, awareness training completion	Access revocation requests; disciplinary cases; awareness training completion rates; personnel security policy	Owens JML process; drives security awareness delivery; manages disciplinary action for policy violations; supports insider threat investigations
IT / Technology	Technical authority over infrastructure; implements controls directed by CISO	Secure, reliable operations; service continuity; technical control implementation	Security architecture standards; patching priorities; vulnerability scan results; change-control decisions	Implements and operates security controls; manages change process; owns technical incident response; maintains privileged access controls
Business Unit Leaders	Operational authority within their business unit; control implementation owners	Operational performance, local security decisions, employee productivity, regulatory compliance in their unit	Security policies applicable to their unit; risk decisions affecting their operations; incident data relevant to their systems	Implement controls within their business unit; appoint BU Security Champions; participate in governance committees; escalate local risks

1.3 Security Governance Organisation Chart



1.4 Consultant Justification

Why This Structure is Appropriate for TechGlobal

In the case of TechGlobal (with 2,500 employees, five global offices, and an increasingly profitable technology product organization), there is clearly an inflection point in their growth that reflects the structural inadequacies in the governance structure as the scale increases beyond what was previously manageable (e.g., 500 employees). Ineffectiveness in addressing this situation leads to potential regulatory, reputational, and operational risks.

The four-tier governance model offered in this scenario is specifically crafted to address the unique needs of the particular organization. As it does not apply either the start-up type of governance model (where the CEO may have to rely solely on the Chief Information Security Officer's services) or the fully-fledged bureaucratic model (as in FTSE 100 financial institution, where one would expect a Governance, Risk, and Compliance (GRC) department comprising approximately 50 people), it provides the following:

- Visibility at the Board level while keeping the Board from managing the operational security — in comes the ESC to provide a mechanism of converting operational risk information to the material risk report for the Board action without the operational overhead.
- Cross functional decision making via the Security Governance Committee (SGC) held monthly and composed of Legal, Finance, HR, IT and Business Unit representatives. This addresses the current silo of IT unilaterally making security decisions.
- Specialisation in operations through working groups (Cloud Security, Incident Response, Third Party Risk) that allow the subject matter experts to focus on particular governance challenges without adding new headcount to the structure.
- Integration of Business Units without fragmentation — BU Security Champions join the SGC but do not operate their own security function, thus preserving the enterprise governance approach while allowing the local accountability.
- Scalability — the committee structure can easily accommodate additional working groups, new business units or increasing regulations without needing to redesign the whole approach. This is a key feature of the growing organization.

This governance model takes inspiration from the ISO/IEC 27001:2022 standard (which mandates the need for having documented governance and defined roles, along with commitment from the senior management), NCSC Board Toolkit

(which calls for direct CISO access to the Board Audit Committee), and NIST CSF 2.0 (which defines Govern as one of the core functions). This governance model has all three properties - regulatory defensibility, board clarity, and operational practicability.

TASK 2 — Governance Responsibility and Authority Matrix (20 Marks)

 **EVIDENCE:** Evidence Bundle 2: Responsibility Matrix · Role Profiles · Conflict-Resolution Note

2.1 Cross-Functional Governance Responsibility Matrix

Role	Purpose	Core Governance Responsibilities	Decision Authority	Reports / Escalates To	KPIs / Evidence
Board / Audit & Risk Committee	Provide strategic oversight; set cyber-risk appetite; hold management accountable	Approve cyber-risk appetite statement; ratify security strategy; review material incidents; approve major security investments above CEO threshold; hold CEO accountable for programme effectiveness.	Final authority on cyber-risk appetite; material risk acceptance above CEO threshold; executive accountability decisions	Shareholders / Regulators	Annual cyber-risk assurance report received; cyber-risk appetite reviewed annually; ≤24h notification of Critical incidents; no more than 1 unresolved Critical Board risk item per quarter
CEO	Bridge Board risk appetite and operational delivery; champion security culture	Approve security strategy; hold CISO and executive team accountable for security performance; resolve cross-functional conflicts; authorise emergency security spend; communicate security commitments externally	Risk acceptance within Board-approved appetite; executive spend approval; CISO appointment and removal; public disclosure decisions	Board of Directors	Monthly executive security summary reviewed; cross-functional conflicts resolved within 5 business days; security strategy reviewed annually
CISO	Lead the security governance programme; own security strategy, policy, and risk oversight	Define and maintain security strategy, policies, and standards; chair Security Governance Committee; present quarterly to Board Audit Committee; manage CISO incident log; own risk register; oversee programme delivery; direct incident response for High and Critical events	Approve security policies and standards; direct incident response resource; escalate to CEO/Board for Critical incidents; veto production changes with unacceptable security risk	CEO (operational); Board Audit & Risk Committee (direct for material matters)	SLA breach rate for High/Critical incidents; % policy review cycle compliance; Board risk register currency; security programme budget utilisation ±10%
CRO / Risk	Maintain an integrated enterprise risk view; challenge and validate CISO risk assessments	Maintain enterprise risk register; validate CISO risk quantification; approve risk treatment decisions within risk appetite; report integrated cyber-risk view to Board; challenge assumptions in CISO risk assessments	Risk acceptance within delegated appetite; enterprise risk register decisions; challenge CISO risk classifications	Board Audit & Risk Committee; CEO	Enterprise risk register updated quarterly; ≥3 independent risk challenges documented per quarter; integrated risk report delivered to Board on schedule
Legal / Compliance	Provide regulatory and contractual governance; own breach	Advise on regulatory notification obligations and timelines; approve external security	Decision authority on regulatory breach notification	CEO; Board (via CEO for material)	Regulatory notification tracker current; 100% of breach notifications issued within statutory deadline; zero

	notification decisions	communications; provide legal privilege protection for investigations; maintain regulatory obligation tracker; advise on third-party contract security terms	timing and content; approval of public statements on security incidents; legal hold decisions	regulatory matters)	unapproved external security communications
Finance	Govern cybersecurity budget; quantify financial risk exposure	Approve annual security budget; authorise emergency security spend within delegated limits; manage cyber insurance programme; quantify financial impact of incidents; include cyber-risk in financial risk reporting	Budget approval up to Board-approved security spend envelope; emergency spend up to defined threshold; cyber insurance coverage decisions	CEO; Board Audit & Risk Committee (for budget items exceeding authority)	Security budget variance ≤10% quarterly; cyber insurance renewal completed ≥60 days before expiry; financial impact estimates provided for all High/Critical incidents within 48 hours
HR	Manage people-related security governance; own joiner/mover/leaver controls	Own and operate JML access provisioning and de-provisioning process; deliver security awareness programme; manage disciplinary action for policy violations; support insider threat investigations with Legal; maintain background screening standards	Disciplinary action decisions; security awareness programme content and delivery; background screening requirements	CEO; CISO (for security-relevant disciplinary and awareness matters)	Access de-provisioned within 4 hours of departure notification; security awareness completion rate ≥95% annually; zero lapsed background screenings for privileged-role employees
IT / Technology	Implement and operate security controls; own the change-management process	Implement controls directed by CISO; maintain the change-control process with dual approval; manage vulnerability patching within defined SLAs; own privileged access technical controls; operate security tooling; provide technical incident response capability	Technical control implementation decisions; change approval within defined change authority matrix; emergency change authority within defined thresholds	CISO (for security matters); CTO/IT Director (for operational IT matters)	Critical patch deployment within 72 hours; change-control compliance rate ≥98%; Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR) for security events reported monthly

2.2 Role Profiles — Decision Authority Cards

CISO — Extended Role Profile

Dimension	Detail
Full Title	Chief Information Security Officer — TechGlobal
Reporting Line	Reports to CEO; direct and independent access to Board Audit & Risk Committee on material security matters
Functional Authority	Functional authority over IT Security, SOC, GRC team, Security Champions network, and all employees for security policy compliance

Decision Authority — Can Act Alone	Security policy approval; incident response resource deployment; security architecture approval for Low/Medium risk changes; risk register updates
Decision Authority — Requires CEO Approval	Security budget requests above threshold; public disclosures on security incidents; ransom payment decisions; CISO programme restructure
Decision Authority — Requires Board Approval	Annual security strategy; cyber-risk appetite statement; major security investments above defined threshold; acceptance of residual material risk
Escalation Obligation	Must notify CEO within 1 hour of confirming a Critical incident; must notify Board Audit Committee Chair within 4 hours; must initiate regulatory notification assessment within 2 hours of confirmed data breach
Cannot Act	Cannot self-approve risk acceptance above defined threshold; cannot approve their own budget; cannot authorise ransom payment without Board/CEO authority
KPI 1	Critical incident Board notification: within 4 hours of confirmation — target 100%
KPI 2	Security policy review cycle compliance: all policies reviewed within defined cycle — target $\geq 95\%$

Business Unit Leader — Extended Role Profile

Dimension	Detail
Role in Governance	Accountable for security control implementation within their business unit; participates in Security Governance Committee
Decision Authority	Local operational security decisions within Board-approved risk appetite and CISO-approved policies; cannot accept enterprise-level risk
Accountability	Accountable to CISO for control implementation; accountable to CEO for business unit security performance
BU Security Champion	Appoints one Security Champion per office or function who acts as the local security liaison to the SGC
Escalation Obligation	Must escalate any security event that could affect other business units, customers, or regulatory obligations to CISO within 2 hours
KPI 1	Security awareness completion rate within BU: target $\geq 95\%$
KPI 2	Open audit findings within BU resolved within agreed timelines: target $\geq 90\%$

2.3 Conflict-Resolution Note

Three Areas of Overlapping Authority and Resolution Principles

#	Conflict Area	Roles Involved	Resolution Principle
1	CISO vs CRO on Risk Acceptance Authority — both functions have risk-related mandates. Without a clear boundary, the CISO may accept enterprise-level risks that require CRO validation, or the CRO may second-guess CISO operational security decisions.	CISO / CRO	Resolution: Define a Risk Acceptance Authority Matrix (RAAM) that specifies risk acceptance authority by risk level. CISO accepts operational risks (Low/Medium). CRO co-signs acceptance of High risks. Both CISO and CRO recommend, and CEO or Board accepts, Critical/Material risks. The RAAM is Board approved and reviewed annually. Documented risk acceptance decisions require sign-off from the authority level specified in the RAAM.
2	Legal vs CISO on Incident Communication — during an incident, CISO may want to communicate rapidly with affected parties, while Legal requires review of all external communications. This tension	CISO / Legal	Resolution: The Incident Communication Protocol (embedded in the Incident Response Plan) defines that CISO owns technical communication to internal stakeholders, while Legal must pre-approve any external communication (customer, regulator, media). Legal must

	can delay communications or cause legally problematic disclosures.		provide review within 2 hours of a draft submission during an active incident. The CEO has authority to override Legal on timing (not content) where regulatory deadlines require it. A pre-approved communication template library reduces the review burden.
3	Finance vs CISO on Security Budget Authority — Finance controls budget approval and may challenge or reduce CISO budget requests based on financial considerations, potentially weakening security controls without security oversight of the trade-off.	CISO / Finance	Resolution: The annual security budget is decided on by the Board as part of the enterprise risk management process and not just Finance. The job of Finance is to manage the spending within the envelope decided upon by the Board, not to define the envelope. It is up to the CISO to provide the risk justification for all of the budget requests made by the Board or ESC. If Finance wishes to cut back on a budget line approved by the Board, the CISO can escalate the residual risk.

TASK 3 — Security Governance Committee Ecosystem (20 Marks)

EVIDENCE: Evidence Bundle 3: Committee Diagram · ToR · Sample Agenda · Decision Log · Calendar

3.1 Committee Structure and Interaction



3.2 Executive Security Council (ESC)

Element	Definition
Purpose	Strategic oversight of TechGlobal's enterprise security posture; approval of security strategy and major risk decisions; escalation point for matters exceeding CISO/SGC authority
Chair	CEO
Members	CISO (secretary); CRO; General Counsel / Legal; CFO / Finance; CHRO / HR; CTO / IT
Frequency	Quarterly as scheduled; ad hoc within 24 hours for Critical incidents or material risk events
Quorum	CEO + CISO + any two other members
Key Responsibilities	Approve annual security strategy; accept material cyber-risks; review CISO programme performance; resolve cross-functional conflicts escalated from SGC; brief the Board Audit & Risk Committee
Outputs	Risk acceptance decisions; strategy approvals; Board briefing material; ESC decision log entries
Escalation to Board	Any incident requiring Board-level risk acceptance; regulatory penalty exposure >USD 500K; public disclosure of a security breach; residual risks exceeding Board-approved appetite

3.3 Security Governance Committee (SGC) — Terms of Reference

TERMS OF REFERENCE — SECURITY GOVERNANCE COMMITTEE

Purpose

The Security Governance Committee (SGC) is TechGlobal's primary cross-functional governance forum for information security. It provides a structured, multi-stakeholder mechanism for reviewing security risks, making cross-functional governance decisions, monitoring programme delivery, and escalating material matters to the Executive Security Council.

Authority

The CEO authorises the SGC and operates within the scope defined by the Board-approved security governance framework. The SGC may make governance decisions within the CISO's delegated authority. Decisions requiring CEO or Board approval must be escalated with a documented recommendation from the SGC.

Membership

Role	Member	Attendance
Chair	CISO	Mandatory
Secretary	GRC Manager / Security Governance Lead	Mandatory
IT / Technology	Head of IT Security or nominated deputy	Mandatory
Legal / Compliance	General Counsel or Senior Legal Counsel	Mandatory
Finance	Head of Finance or CFO delegate	Standing
Human Resources	HR Director or delegate	Standing
BU Security Champions	One Champion per business unit (rotating chair of Champion network)	Standing
CRO / Risk	CRO or Risk Manager	Invited / Standing for risk items
Guest	Subject-matter experts for specific agenda items	As required

Meeting Frequency and Quorum

- Regular meetings: Monthly, on the third Tuesday of each month, 10:00–11:30 WAT.
- Emergency meetings: Within 4 hours of a Critical incident or material governance event.
- Quorum: CISO + IT + Legal + at least two other standing members.
- Meetings may be held virtually or in-person. Votes require quorum. Tied decisions escalate to the CISO as deciding authority.

Standing Agenda Items

1. Incident Review — status of High/Critical incidents; SLA compliance; escalation decisions
2. Risk Register Review — new risks; risk treatment updates; risks approaching appetite threshold
3. Policy and Standards — policy review status; new policy requirements; exception requests
4. Programme Delivery — CISO programme milestone updates; budget status; KPI review
5. Third-Party Risk — vendor risk review; new vendor onboarding approvals
6. Escalation Decisions — items requiring ESC or Board approval
7. Actions Review — previous meeting actions; owners; due dates

Decision-Making

Decisions are made by consensus where possible. Where consensus cannot be reached, the Chair (CISO) has the casting vote for matters within CISO authority. Decisions exceeding CISO authority are documented as SGC recommendations and escalated to the ESC with supporting rationale. All decisions are recorded in the SGC Decision Log and distributed to members within 48 hours of the meeting.

Reporting

The CISO produces a monthly SGC summary for the ESC and a quarterly security dashboard for the Board Audit & Risk Committee. Material escalation items are communicated outside of the regular meeting cycle where timeliness requires it.

Review

These Terms of Reference are reviewed annually by the CISO and approved by the CEO. Material changes to governance structure require ESC approval.

3.4 Cloud Security Working Group

Element	Definition
Purpose	Provide specialised governance oversight of TechGlobal's cloud security posture, including cloud architecture security reviews, CSPM governance, cloud vendor risk, and cloud incident response readiness
Chair	Head of Cloud Infrastructure (or designated Cloud Security Lead)
Members	CISO (sponsor); Cloud Architecture team; DevOps leads; GRC; Legal (for cloud data residency matters); Finance (for cloud spend governance)
Reports To	Security Governance Committee (monthly status update); escalates cloud-specific risks to CISO
Frequency	Bi-weekly; ad hoc for cloud security incidents
Key Outputs	Cloud Security Posture Management (CSPM) status report; cloud misconfiguration register; cloud vendor security assessment results; cloud architecture security decisions

3.5 Business Unit Participation Model

TechGlobal's governance framework includes a Security Champion Network within the Business Units, designed to avoid the establishment of separate BU security silos and guaranteeing local responsibility:

- One Security Champion is designated by each Business Unit, being a technologically aware staff member that serves as the liaison between their BU and the Security Governance Committee. The Champions are not security specialists; they are informed proponents of security.
- They attend the monthly SGC, inform about security risks in their region, monitor the state of awareness completion and audit findings at their BU level, and deliver governance decisions back to their BU.
- A quarterly Champions Forum is held by the CISO, sharing lessons learned, communicating policy changes, and aligning BU-level security initiatives with the enterprise-level initiative.
- The BU Leaders are responsible for security outcomes in their BU. Champions are the means, not the accountability - BU Leaders cannot shift governance responsibility to Champions.

3.6 Sample SGC Meeting Agenda

SECURITY GOVERNANCE COMMITTEE — SAMPLE MEETING AGENDA

Date: Tuesday, 21 October 2026 | Time: 10:00–11:30 WAT | Venue: Virtual / VC-Room B2

Time	Agenda Item	Lead	Objective
10:00–10:05	Welcome, apologies and quorum confirmation	Chair (CISO)	Confirm quorum; record apologies

10:05–10:15	Actions from previous meeting (18 September 2026)	Secretary (GRC)	Close completed actions; escalate overdue items
10:15–10:30	Incident Review — INC-2026-047 (Cloud Exposure, Critical) and INC-2026-051 (Phishing campaign, High)	Head of IT Security	Review status, containment, and SLA; decide on ESC escalation need
10:30–10:40	Risk Register Update — Third-party vendor risk: new SaaS platform onboarding	CRO Representative	Review vendor risk assessment; approve or escalate acceptance decision
10:40–10:50	Policy Review — Remote Access Policy (annual review due)	GRC Manager	Review proposed amendments; approve or escalate for ESC sign-off
10:50–11:00	Cloud Security WG Report — Q3 CSPM status and open misconfigurations	Cloud WG Chair	Receive status; direct remediation priorities
11:00–11:10	Security Awareness — Q3 completion rates by BU; low-completion BU action plan	HR / BU Champions	Review rates; agree remediation action with responsible BU Champion
11:10–11:20	Programme Update — CISO quarterly board report preparation; KPI review	CISO	Review KPIs; confirm board report content
11:20–11:28	Escalation Items — draft recommendation to ESC on Cloud Security CSPM tool investment	CISO	Finalise ESC recommendation; agree on presenter
11:28–11:30	Date of next meeting; close	Chair	Confirm 18 November 2026

3.7 Sample SGC Decision Log

Date	Decision / Issue	Decision Owner	Decision Made	Rationale	Actions / Owner	Review Date
21 Oct 2026	Remote Access Policy — Annual Review	CISO	Approved with amendments: MFA requirement extended to all third-party remote connections; 30-day grace period for existing third-party connections	Three recent phishing incidents exploited third-party remote sessions without MFA; Legal confirmed regulatory obligation to protect third-party access points under NIS2 equivalents	IT Security to enforce MFA for all third-party remote connections by 20 Nov 2026 / IT Director	19 Nov 2026
21 Oct 2026	CSPM Tool Investment — Recommendation to ESC	CISO (recommended); ESC (decided)	SGC recommends ESC approval of CSPM tool procurement (budget: USD 120,000 p.a.); escalated with supporting risk data from Cloud WG	Cloud Exposure incidents increased from 0 in 2024 to 11 in 2025; current manual review is insufficient; CSPM reduces misconfiguration detection time from weeks to hours	CISO to present to ESC on 10 Nov 2026; Finance to confirm budget availability / CISO + CFO	10 Nov 2026
21 Oct 2026	INC-2026-047 Cloud Exposure — Escalation Decision	CISO	Escalated to ESC for material risk acceptance; incident remains open with partial containment; data exposure scope not yet confirmed	Incident meets ESC escalation threshold: Critical severity, potential regulatory exposure (Privacy data), cost estimate exceeds USD 100,000; Legal confirmed regulatory notification assessment required	CISO to brief ESC Chair by 22 Oct 2026; Legal to initiate regulatory notification assessment by 22 Oct 2026 / CISO + General Counsel	22 Oct 2026

3.8 Twelve-Month Governance Calendar

Month	Governance Activity	Owner	Forum
January	Security programme annual review; CISO Board presentation; Risk appetite review	CISO	ESC → Board
January	Q4 prior year incident close-out; SLA performance review	IT Security / CISO	SGC
February	Annual security policy review cycle begins; Vendor risk register refresh	GRC / CISO	SGC
February	Security awareness programme Q1 launch; BU Champion quarterly forum	HR / CISO	SGC / Champions Forum
March	Q1 CISO Board dashboard delivered; ESC quarterly meeting	CISO	ESC → Board
March	Penetration testing programme kick-off (annual); Findings review scheduled	CISO / IT	SGC
April	Penetration test findings review; Remediation RACI assigned	IT Security / CISO	SGC
April	Third-party vendor security assessments — Q2 cycle	GRC	SGC
May	Cyber insurance renewal (if annual); Finance / CISO joint review	Finance / CISO	ESC
May	Security awareness Q1 completion rates reviewed; Low-completion BU remediation	HR / BU Champions	SGC
June	Q2 CISO Board dashboard; ESC quarterly meeting; Mid-year risk register review	CISO / CRO	ESC → Board
June	Business continuity / DR test scheduled; Incident response tabletop exercise	IT / CISO	Working Group
July	BU Security Champion quarterly forum; H1 lessons-learned session	CISO	Champions Forum
July	Cloud security posture mid-year review; CSPM findings prioritisation	Cloud WG / CISO	SGC
August	Security awareness Q2 completion review; Annual awareness programme update	HR / CISO	SGC
August	Third-party vendor security assessments — Q3 cycle	GRC	SGC
September	Q3 CISO Board dashboard; ESC quarterly meeting; Risk appetite mid-point check	CISO	ESC → Board
September	Regulatory compliance review; Legal obligation tracker update	Legal / CISO	SGC
October	Annual security awareness programme renewal; New phishing simulation campaign	HR / IT	SGC
October	Cloud Security WG Q3 report; CSPM tool review	Cloud WG	SGC

November	Penetration testing results — annual cycle close; Remediation status	IT Security / CISO	SGC
November	BU Security Champion quarterly forum; H2 lessons-learned	CISO	Champions Forum
December	Q4 CISO Board dashboard; ESC quarterly meeting	CISO	ESC → Board
December	Year-end security programme review; Next-year roadmap and budget preparation	CISO / Finance	ESC

TASK 4 — RACI Accountability Matrix (20 Marks)

EVIDENCE: Evidence Bundle 4: RACI Matrix · Implementation Guide

4.1 TechGlobal RACI Matrix

The matrix below assigns a single Accountable (A) role per activity. Gold cells denote the Accountable role. R = Responsible, C = Consulted, I = Informed. BU = Business Unit Leader.

Governance Activity	Board	CEO	CISO	CRO	Legal	Fin	HR	IT	BU
Cybersecurity strategy approval	A	R	R	C	C	C	I	I	I
Security policy approval	I	I	A	C	C	I	C	R	I
Enterprise cyber-risk assessment	I	I	R	A	C	C	I	C	C
Risk acceptance	A	R	C	R	C	C		I	I
Security budget approval	I	C	R	C	I	A	I	C	I
Security architecture approval	I	I	A	C	C	I		R	C
Third-party security review	I	I	A	C	C	C		R	C
Access governance	I	I	A	I	C	I	R	R	C
Incident response governance	I	C	A	C	R	C	C	R	I
Material incident escalation	I	R	R	C	C	C	I	I	I
Regulatory notification decision	I	C	R	C	A	C		I	I
Security awareness programme	I	I	C	I	C	I	A	C	R
Vulnerability remediation oversight	I	I	A	C	I	I		R	C
Business continuity/recovery governance	I	C	C	C	C	C	C	A	C
Board cyber-risk reporting	A	C	R	R	C	C	I	I	I

Key: A = Accountable (Gold — single owner per activity); R = Responsible; C = Consulted; I = Informed. Blank = not involved.

4.2 Problematic RACI Assignments — Three Issues and Resolutions

#	Activity	Potential Problem	Resolution
1	Risk Acceptance — Board is Accountable but multiple roles are Responsible	Having both CEO (R) and CRO (R) responsible for risk acceptance without clear boundary conditions creates ambiguity about who leads the risk acceptance	Resolution: The Risk Acceptance Authority Matrix (RAAM) defines which party leads the recommendation based on risk level. For Low/Medium: CISO recommends, CRO validates. For High: CISO and CRO co-recommend to CEO. For Critical/Material:

		recommendation. In practice, this can cause neither role producing the recommendation, or both producing conflicting recommendations.	CEO recommends to Board. The Board Accountable designation means it holds the final acceptance authority, not that it performs the analysis.
2	Material Incident Escalation — CEO is Responsible but is not always immediately available	During a real Critical incident, a Responsible assignment to the CEO without a defined deputy or alternate creates a practical escalation gap. If the CEO is unreachable, no one has clear authority to act on the escalation.	Resolution: The Incident Response Plan designates the COO (or another C-suite delegate) as the CEO's escalator alternate with equivalent authority during declared incidents. This alternative is documented in the IRP and tested during tabletop exercises. The RACI should be read with the IRP, not as a standalone document.
3	Business Continuity / Recovery Governance — IT is Accountable, not CISO	This assignment could create tension: IT is accountable for recovery operations, but the CISO is accountable for the overall incident governance. During a ransomware event, a conflict between IT's recovery prioritisation and the CISO's containment requirements could produce competing decisions.	Resolution: The CISO holds governance authority over the incident as a whole. The 'IT's Accountable' designation for business continuity/recovery means IT is accountable for the technical recovery execution. A documented escalation principle in the IRP states: where CISO containment decisions conflict with IT recovery decisions, CISO's authority prevails until containment is confirmed, after which IT leads recovery under CISO oversight.

4.3 RACI Implementation Guide — One-Page Manager Reference

HOW TO USE THE TechGlobal RACI MATRIX — MANAGER REFERENCE

During Normal Operations (Planning and Approvals)

- Prior to the governance activity, identify your role in the RACI chart. If you are Responsible (R): you perform the activity and produce the output. If you are Consulted (C): you give input before any decision is made - your input is required, not optional. If you are Informed (I): you receive the output but don't have to do anything about it.
- It's up to the Responsible party to drive each activity forward. If nobody in your group is R, then reach out to the Accountable (A) for clarification on what needs to be done.
- Only one Accountable (A) per activity. If you're the Accountable, you take ownership of the activity's outcome and you can't transfer that accountability even if you can transfer its performance. You are the person who makes the decision.
- For Approval activities (for example, Security Budget Approval, Security Policy Approval): an approval from the Accountable role in writing is required to consider the activity completed.

During Incidents

For High or Critical incidents, the RACI definitions of "Incident Response Governance" and "Material Incident Escalation" shall be used as the source of decision-making authority. Decision making by the Accountable (CISO) party shall not occur without prior delegation.

- The CISO (Accountable for Incident Response Governance) holds the authority to supersede all standard Responsible roles during an incident and direct a team to perform certain actions.
- If the Responsible party for any activity is unavailable during an incident, the next direct supervisor holds the position of the Responsible role. In case the Accountable party is unavailable, the alternate (stated in IRP) becomes the new Accountable person.
- All decisions made during incidents shall be added into the Incident Decision Log within one hour after being made. Unlogged decisions during incidents will be treated as governance failure during a post-incident analysis.

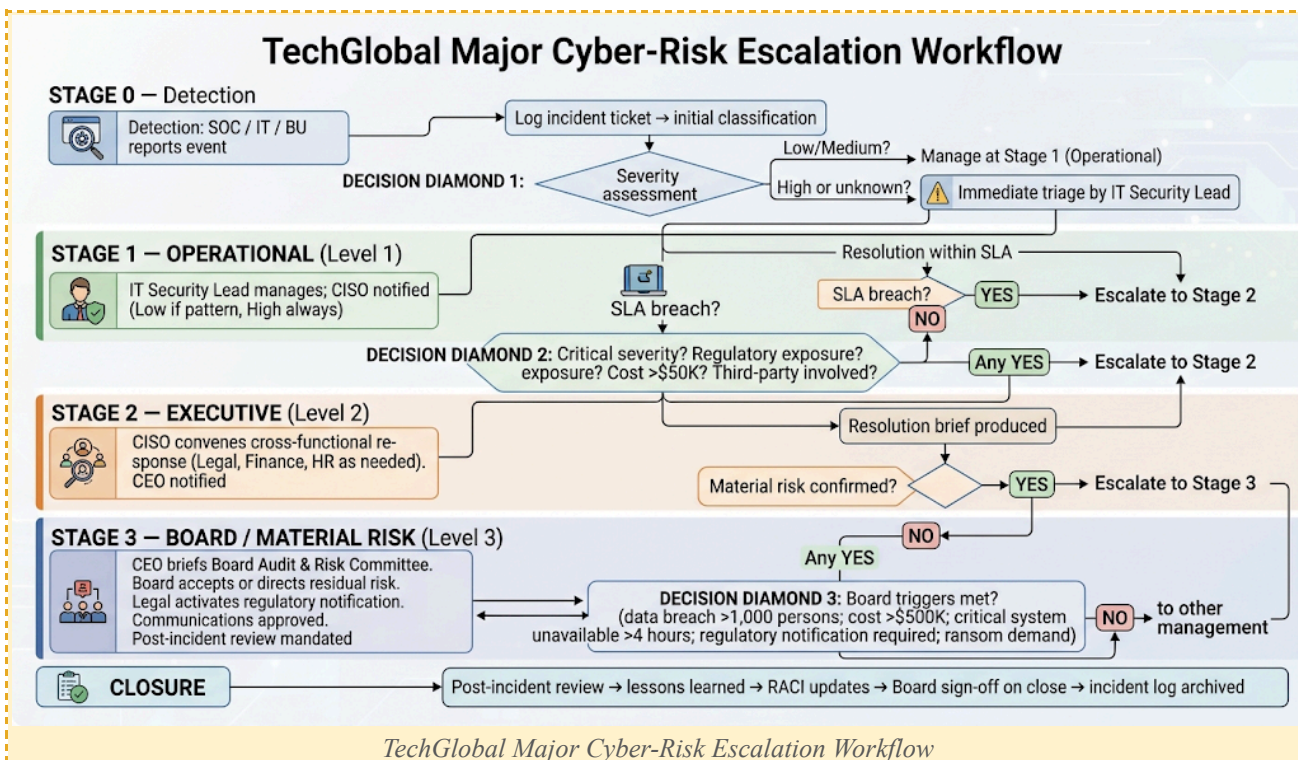
Common Mistakes to Avoid

- Do not treat C as optional — Consulted roles must be engaged before decisions are finalised. Bypassing a C creates audit gaps and may invalidate a decision.
- Do not add additional Accountable roles — the RACI specifies one A per activity. If you believe two roles share accountability, escalate this to the CISO for RACI review; do not resolve it informally.
- Do not use the RACI as a substitute for judgement — the RACI defines authority, not action. If a situation falls outside defined activities, escalate to CISO.

TASK 5 — Cyber-Risk Escalation and Segregation of Duties (20 Marks)

EVIDENCE: Evidence Bundle 5 & 6: Escalation Workflow · Threshold Table · SoD Register · Assurance Note

5.1 Major Cyber-Risk Escalation Workflow



5.2 Escalation Threshold Table

Level	Trigger Criteria (any one is sufficient)	Decision Authority	Required Notifications	Target Response / Decision Time
Level 1 Operational	- Incident classified Low or medium-severity - No confirmed regulatory exposure - No third-party involvement with data access - Cost estimate: <USD 25,000 - Contained within a single system or team	IT Security Lead (operational); CISO informed for High-end Medium incidents	CISO: Informed within 4 hours for all Medium incidents; within 2 hours for Medium incidents with regulatory exposure possibility	Initial response: within 1 hour of detection Containment: within SLA target (Medium: 14 days; Low: 30 days) Escalation trigger: SLA breach or severity reclassification
Level 2 Executive	- Incident classified High severity - Possible regulatory exposure (Privacy, Financial Data, contractual) - Third-party vendor materially involved - Cost estimate USD 25,000–500,000 - Multiple departments affected - SLA breach at Level 1 for a High incident	CISO (primary decision authority); CEO notified; CRO/Legal/Finance convened as required	CEO: Notified within 1 hour of Level 2 declaration Legal: Engaged within 2 hours to assess regulatory notification CRO: Notified within 2 hours for risk quantification Finance: Engaged within 4 hours for cost estimation	CISO decision within 4 hours of Level 2 declaration Regulatory assessment within 2 hours of Legal engagement CEO decision on escalation to Level 3 within 6 hours

	• Unresolved Medium incident with escalating cost or scope			
Level 3 Material / Board	• Incident classified Critical severity • Confirmed data breach >1,000 individuals or any volume of regulated data • Ransomware affecting critical business systems • Critical system unavailable >4 consecutive hours • Estimated cost impact >USD 500,000 • Regulatory notification obligation confirmed • Threat of public disclosure or media involvement • Ransom demand received	CEO (presents to Board); Board Audit & Risk Committee (risk acceptance and disclosure decisions); Legal (notification authority)	Board Chair / Audit Committee Chair: Notified within 4 hours of Level 3 declaration Regulatory authority: Notified per statutory deadline (e.g., 72 hours under applicable data protection law) Cyber insurer: Notified within 24 hours External legal counsel: Engaged immediately	Board convened within 24 hours (emergency session if required) Public/customer notification: Per Legal and Board approved timeline Residual risk decision: Within Board meeting Post-incident review: Initiated within 72 hours of containment

5.3 Segregation of Duties and Accountability Weakness Register

ID	Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
SOD-01	IT Director self-approves production changes and also validates their own risk assessment	Change-control failure; fraud risk; inability to detect errors or deliberate misconfigurations introduced by the IT Director; ISO 27001 and audit non-compliance	IT Director (initiates changes, approves changes, assesses risk)	Enforce mandatory four-eyes principle: all production changes require approval from a Change Advisory Board (CAB) member who is independent of the initiator. Privileged-system changes require CISO or Security Manager co-approval. Change log reviewed monthly by CISO.	Residual: low if CAB is operational. Review: quarterly CAB effectiveness audit by internal audit.
SOD-02	The same team (IT) that implements security controls also tests and reports their effectiveness	Conflict of interest in control testing; CISO and Board receive potentially biased assurance that controls are working; regulatory auditors will flag this as an independence deficiency	IT Security (implements controls, runs vulnerability scans, produces effectiveness reports)	Establish an independent assurance function (Internal Audit or contracted third party) to conduct control effectiveness testing separately from the IT team. CISO reviews IT-produced metrics but also receives independent assurance reports. An annual penetration test by an external party is mandatory.	Residual: medium until independent assurance function is operational. Review: annually by CISO and Internal Audit.
SOD-03	CISO both manages the security programme and self-reports its performance to the Board	The Board receives CISO-filtered reporting with no independent verification; material control failures or governance weaknesses may be underreported or contextualised in ways that protect the programme	CISO (programme owner and sole Board reporter)	Require the CRO or Internal Audit to provide an independent assurance opinion alongside the CISO's Board report at least annually. The Board Audit Committee should have the right to commission independent security assessments without CISO involvement. Establish a Board-approved set of minimum KPIs that the CISO must report against (not self-select).	Residual: low if CRO/Audit independence is genuine. Review: annually by the Board Audit Committee.

SOD-04	IT Operations team has unrestricted privileged access to production systems with no monitoring or session recording	Insider threat risk; inability to detect unauthorised changes; no audit trail for privileged actions; inability to reconstruct events in forensic investigations; regulatory non-compliance with audit log requirements	IT Operations / System Administrators (privileged access, no oversight)	Implement a Privileged Access Management (PAM) solution with session recording for all privileged access. Enforce just-in-time (JIT) access provisioning so privileged access requires approval per session rather than standing permissions. CISO reviews privileged access logs monthly. Implement automated alerting for anomalous privileged access patterns.	Residual: low once PAM is deployed. Review: quarterly access review by CISO; annual PAM configuration audit.
SOD-05	HR manages the joiner/mover/leaver (JML) process but has no visibility into whether IT has actually executed access changes — and IT has no obligation to confirm completion to HR	Dormant accounts remain active after employees leave or change roles; excessive privileges accumulate through role changes without review; insider threat and access control risk increases over time	HR (owns JML process, no visibility of execution); IT (executes access changes, no obligation to confirm back)	Implement a closed-loop JML process: IT must acknowledge and confirm access de-provisioning within 4 hours of HR notification. Failure triggers an automatic CISO alert. HR runs a monthly reconciliation between employee status (active/terminated) and IT account status, with exceptions reviewed by CISO. Access reviews at role changes require both HR (confirmation of new role) and IT (confirmation of access change) sign-off.	Residual: low once closed-loop process is operational. Review: monthly reconciliation report to CISO; quarterly audit by GRC.

5.4 Decision-Recording and Assurance Note

How Significant Decisions Will Be Recorded, Tracked, Reviewed and Closed

Dimension	Control and Mechanism
Recording	Every governance decision made at SGC, ESC, or Board level is entered into the Security Governance Decision Log within 48 hours of the meeting. Incident decisions are entered into the Incident Decision Log within 1 hour of being made. Both logs are maintained in a centralised GRC platform accessible to CISO, CRO, Legal, and Internal Audit.
Minimum Decision Record	Each entry captures: Date; Decision or issue title; Decision owner (Accountable role); Decision made; Rationale (including data or risk assessment relied upon); Dissenting views (if any); Actions arising with named owner and due date; Review / follow-up date.
Tracking	Open decisions and actions are tracked on the SGC rolling action log, reviewed at every monthly meeting. Overdue actions escalate automatically to the CISO within 5 business days of their due date. Critical incident decisions are tracked in a dedicated incident management platform with daily status updates during the active incident.
Review	All decisions made in response to Level 2 and Level 3 incidents are reviewed as part of a post-incident review (Hot Wash) within 72 hours from when the incident is closed out. The review will consider if the correct decision has been made based on the facts at hand; if the decision has been made appropriately; if the RACI has been properly followed; and any required change in policy/process/controls.
Closure	A decision is closed when: all actions arising from it are completed and confirmed; the review date has passed with no further action required; and the Accountable role confirms in writing (or in the decision log) that the outcome is satisfactory. Closed decisions are retained in the log for a minimum of 5 years for audit and regulatory purposes.
Assurance	Internal Audit reviews the decision log quarterly and provides an independent assurance report to the Board Audit Committee. The assurance report confirms: decisions were made by the correct authority; rationale was documented; actions were completed within agreed timelines; no decisions were made outside the governance framework without escalation.

References

- ISO/IEC 27001:2022. Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements. ISO.
- NIST (2024). NIST Cybersecurity Framework 2.0. National Institute of Standards and Technology. Available at: <https://doi.org/10.6028/NIST.CSWP.29>
- NCSC (2022). Board Toolkit: Cyber Security for Directors. National Cyber Security Centre. Available at: <https://www.ncsc.gov.uk/collection/board-toolkit>
- CISA (2023). CISA CISO Handbook. Cybersecurity and Infrastructure Security Agency. Available at: <https://www.cisa.gov/resources-tools/resources/cisa-ciso-handbook>
- ISACA (2019). COBIT 2019 Framework: Governance and Management Objectives. ISACA.
- Calder, A. & Watkins, S. (2019). IT Governance: An International Guide to Data Security and ISO 27001/ISO 27002. 7th ed. Kogan Page.
- European Union (2022). Directive on Measures for a High Common Level of Cybersecurity Across the Union (NIS2), Directive (EU) 2022/2555.
- Nigeria Data Protection Commission (2023). Nigeria Data Protection Act 2023. Federal Government of Nigeria.
- RACI methodology: Project Management Institute (PMI), PMBOK Guide, 7th ed. (2021). Project Management Institute.
- Westerman, G. & Hunter, R. (2007). IT Risk: Turning Business Threats into Competitive Advantage. Harvard Business School Press.

AI Use Declaration

This practical laboratory report was completed with the assistance of Claude (Anthropic) for structural guidance, content organisation, language refinement, and table formatting. Gemini was used for image generation.